

Threat Model Report: B2B SaaS Invoice Platform

Total Threats: 9

1. [HIGH] Process Identity Spoofing

STRIDE Category: Spoofing

Component: Invoice API

Description: An attacker could impersonate this process to other components.

Mitigation: Implement mutual authentication (mTLS, API keys, OAuth2).

2. [HIGH] Process Input Tampering

STRIDE Category: Tampering

Component: Invoice API

Description: Inputs to this process may be manipulated to alter behavior.

Mitigation: Validate and sanitize all inputs. Use integrity checks (HMAC).

3. [HIGH] Privilege Escalation via Internet-Facing Process

STRIDE Category: Elevation of Privilege

Component: Invoice API

Description: Internet exposure increases the attack surface for privilege escalation.

Mitigation: Apply least privilege, use containerization, and WAF protection.

4. [HIGH] Sensitive Data Exposure

STRIDE Category: Information Disclosure

Component: Invoice Database

Description: Sensitive data stored here could be exfiltrated by an attacker.

Mitigation: Encrypt data at rest (AES-256). Apply strict access controls.

5. [HIGH] External Entity Impersonation

STRIDE Category: Spoofing

Component: Client Browser

Description: This external entity could be spoofed by a malicious actor.

Mitigation: Verify identity using certificates or signed tokens (JWT).

6. [HIGH] Unencrypted Data in Transit

STRIDE Category: Information Disclosure

Component: API to DB Channel

Description: Data flowing through this channel may be intercepted.

Mitigation: Enforce TLS 1.2+ on all data flows. Disable plaintext protocols.

7. [MEDIUM] Data Store Integrity Violation

STRIDE Category: Tampering

Component: Invoice Database

Description: An attacker could modify stored records to corrupt system state.

Mitigation: Use audit logs, checksums, and DB-level access restrictions.

8. [MEDIUM] Missing Audit Trail

STRIDE Category: Repudiation

Component: Invoice Database

Description: No proof of who accessed or modified data in this store.

Mitigation: Enable database audit logging and write-protected log storage.

9. [MEDIUM] Unverifiable External Actions

STRIDE Category: Repudiation

Component: Client Browser

Description: Actions by this entity cannot be tied to a verified identity.

Mitigation: Log all interactions with timestamps and authenticated identifiers.